

AIMIFY

Feature Status Report

The proposed feature set compared with what is built today

Status as of 27 September 2026, checked against the aimify-web repository.

Where things stand. Payments are live with Paystack, in test mode: organizations subscribe, renew automatically from a saved card, and get a grace period before locking. Two-factor authentication, revocable sessions, enforced team roles, plan limits, a support inbox and admin insights are also built and tested. The Windows desktop app can now be downloaded from the website. The biggest remaining gap is the customer, supplier, purchase, sale and expense modules, which have no backend yet in this report's checked-in code — blocked on whether the desktop app should sync that data here or keep it local (section 9). Uncommitted, unreviewed code toward that module was found in the project this week and is not reflected in the counts below (section 6).

1. Scope and how to read this

Aimify has two parts. The **desktop app** (Flutter) is the inventory system. The **website** is where people create an account and manage their subscription, and it also hosts the backend API the desktop app signs in to. This report therefore splits the spec into three areas: the website and account layer (section 2), the backend API for the desktop app (section 3), and the desktop app itself (section 4).

Only what is in this repository could be verified. Each item is marked **Done** (built and tested), **Partial** (exists but incomplete, or waiting on something) or **Not built**.

Area	Done	Partial	Not built	Total
Website and account layer	18	3	0	21
Backend API for the desktop app	7	1	5	13

2. Website and account layer

Feature	Status	What is there
Sign up, login, logout	Done	Web, plus token login for the desktop app. Login is rate-limited.
Session management	Done	Every web and desktop sign-in is a server-side session with device, IP and last activity. Users see their signed-in devices in Settings and can sign one out or sign out all others; changing or resetting a password, an admin reset, or removal from a team signs out every device at once. The desktop API has a logout endpoint. Revocation takes effect immediately on the server that handles it and within about 20 seconds on others.
Password reset	Done	Emailed single-use link that works for 1 hour. Admins can also reset a password manually.
Email verification	Done	A confirmation link is emailed at sign-up (valid 24 hours) and can be resent. Unverified users are held before onboarding and the dashboard, and admins can verify someone by hand. Existing accounts were treated as confirmed. Phone verification is not included.
Profile management	Done	Name and phone can be edited; every change is audited.
Change password	Done	Checks the current password first; rate-limited.
Two-factor authentication	Done	Authenticator-app codes (TOTP, checked against the RFC 6238 test vectors) with QR setup, ten single-use backup codes, and a code prompt at web and desktop sign-in. The key is stored encrypted, backup codes are stored hashed, used codes can't be replayed, and wrong codes are rate limited. Turning it on or off needs a code (off also needs the password), signs out other devices and sends an email; admins can reset it for a locked-out user. SMS codes and forced two-factor for admins are not included.
Company profile	Done	Registration number, address, phone, email, tax, time zone and date format all save. The logo uploads to Vercel Blob, replaces cleanly and shows in the sidebar; verified live.
Setup wizard	Partial	Profile, organization and warehouse, trial, download. The products, users and opening-inventory steps belong to the desktop app.
Tenant isolation	Done	Every query is scoped by organization ID (application-level; no database-level row security).
Role-based access control	Done	Team invites and roles on the website (Owners and Administrators invite, change roles and remove people; only Owners cancel the subscription). The desktop API now enforces roles too: Sales Staff can only record stock-out, Inventory Staff can add and edit products and record stock, Warehouse Managers and above also archive products and manage warehouses, and Accountant / Finance is read-only. Blocked calls return 403 with code forbidden_role, and /me lists each role's permissions.

Feature	Status	What is there
Subscription statuses	Done	All seven statuses exist and are enforced. Payments move an organization to active; a failed renewal moves it to past_due for a grace period, then expired.
Trial	Done	14 days, then it expires automatically and locks the desktop app.
Plans and enforced limits	Done	A plans table with price and caps on team members, active warehouses and active products (empty means unlimited). The admin Plans page creates, edits, activates and deactivates plans and sets the default; admins assign a plan to each organization. Limits are enforced when creating or re-activating warehouses and products in the desktop API and when inviting or accepting team members, and customers see their usage on the Billing page. The seeded plan keeps today's behavior: one warehouse, everything else unlimited.
Payment system	Done	Paystack Checkout for the first payment (card, bank transfer or USSD) and automatic monthly renewal by charging the saved card. Webhooks are verified by signature and are idempotent; a checkout also self-verifies when the customer returns. A 3-day grace period after a failed renewal, then the organization locks. Cancelling a paid subscription keeps access until the paid period ends. Refunds are marked from Paystack's webhook; issuing one is still done in the Paystack dashboard. Currently in test mode: switching to live keys and finishing Paystack business verification is still needed before real money can move.
Billing history	Done	Real payment records: checkouts, automatic renewals, failures with the reason, and refunds, each with its paid-until date.
Subscribe, renew, upgrade, cancel	Partial	Subscribe, renew (automatic and manual) and cancel (with a confirm step, keeping access to the paid period) are done. Upgrading or downgrading between plans still needs a decision on proration.
Admin: organizations, suspend and reactivate, activity trail	Done	Detailed organization and user tables: company profile, usage counts, members, last activity and recent history per row. Admin actions: suspend, reactivate, extend a trial, activate manually, reset a password, verify an email or send a confirmation link. Activity has search, area filter and Clear history.
Admin: MRR, churn, plan configuration, payment history, support tickets	Done	An Insights page (MRR, ARR, new and churned MRR, net new MRR, trial-to-paid and churn rates, revenue per organization, a six-month table, revenue by plan, and money actually collected in the last 30 days), a Payments page (every attempt, failures with their reason, refunds), plan configuration (Plans page), and a support inbox where contact-form and dashboard messages become tickets that admins reply to by email, annotate and resolve, with a Support page for customers.

Feature	Status	What is there
Audit logs	Done	User, organization, action, module, record, before and after values, timestamp, and the IP address and device (browser or desktop app), shown in the admin activity trail. Entries written before IP/device logging was added have no IP.
Notifications	Partial	Email for account confirmation, team invitations, password reset, low-stock and out-of-stock alerts, trial reminders (3 days and 1 day before, and when it ends), subscription changes (suspended, reactivated, trial extended, activated, cancelled), and payments (receipt, failed renewal, upcoming renewal, subscription lapsed). Reminders and renewals come from a daily job that needs CRON_SECRET set on Vercel. No SMS, WhatsApp or push.

3. Backend API for the desktop app

Everything the desktop app can do against the web backend today. Modules with no tables or endpoints here may still exist locally in the desktop app; that is covered in section 4.

Feature	Status	What is there
Token login and account lookup	Done	Documented in docs/desktop-api.md.
Subscription check on API requests	Done	402 or 403 with a machine-readable code; login and account lookup stay open.
Products (create, list, get, edit, archive)	Partial	Includes brand, max stock, validation and an image endpoint (PNG, JPEG or WebP up to 2 MB, verified live on Vercel Blob). Missing: the supplier link, because there is no suppliers table.
Product categories and units	Done	Configurable per organization; default units seeded; custom values are added automatically.
Stock in, out, adjustment, count	Done	Atomic updates with a full movement ledger (before and after stock, user, reason).
Real-time current stock	Done	Current stock is kept on each product.
Low-stock and out-of-stock alerts	Done	Returned on the movement that crosses the threshold, listed by an alerts endpoint, and emailed to the organization's members.
Inventory valuation	Not built	No endpoint or calculation.
Warehouses	Done	Create, edit and disable; one active warehouse per plan.
Per-warehouse stock	Not built	Stock is organization-wide on the product. Needs redesign before multi-warehouse (Phase 2).

Feature	Status	What is there
Customers, suppliers, credit sales	Not built	No tables or endpoints in this report's checked-in code. Uncommitted, unreviewed work toward this exists in the project (see section 6) but is not counted here.
Purchases, sales, expenses	Not built	No tables or endpoints.
Stock transfers and returns (Phase 2)	Not built	No tables or endpoints.

4. Desktop app (not verifiable from this repository)

The dashboard and charts, reports, purchase and sales screens, customer and supplier screens, and offline mode all belong to the Flutter project, which is separate. The web backend has no checked-in tables for customers, suppliers, purchases, sales or expenses (see section 6 for uncommitted work in progress toward this), so either the desktop app stores them locally today or they are not built yet. This report cannot tell which.

5. Differentiators and later phases

Feature	Planned	Status	Notes
WhatsApp-native workflows	MVP / near-term	Not built	Nothing built.
Customer credit risk scoring	MVP / near-term	Not built	Needs customer and credit data first.
Photo-evidence stock adjustments	MVP / near-term	Not built	File storage is now in place, but stock movements don't accept a photo yet.
Offline-first with sync	Phase 2	Not built	Desktop-side work. The token-based API suits it.
Mobile application	Phase 2	Not built	Not started.
Multiple warehouses, transfers, returns, report exports	Phase 2	Not built	Warehouses can be created, but only one may be active and stock isn't split per warehouse.
Landed-cost calculator, inter-business network	Phase 2	Not built	Not started.
Accounting, POS, e-commerce, BI, multi-currency, embedded financing	Phase 3	Not built	A v1 API exists, but for the first-party desktop app only: no API keys or third-party access.

The Billing page's plan list and the marketing copy advertise WhatsApp alerts, credit tracking, and purchases and sales. Those may be planned for the desktop app, but nothing on the backend supports them today.

6. Placeholders and things waiting on a decision

- **Paystack is in test mode:** switch to live keys in Vercel Production, and finish Paystack business verification, before accepting real payments.
- **Plan upgrade/downgrade proration:** no decision yet on charging or crediting the difference mid-cycle.
- **Bank transfer and USSD payments can't be auto-renewed:** those customers get an email each cycle instead of a saved card.
- **Customers, suppliers and credit:** uncommitted, unreviewed code for this was found in the project this week, with its database tables already applied to the shared database. It hasn't been reviewed, tested, or counted in this report. Decide whether to review and adopt it, or discard it, once the open question in section 9 is settled.

7. Built beyond the spec

- Launch gate with a countdown page and a developer bypass.
- Contact form that delivers real email through Resend.
- Login rate limiting on both the website and the desktop API.
- Security response headers (content security policy, frame, referrer and permissions policies).
- SEO basics: sitemap, robots file and a social preview image.
- Admin user management with generated or manual password resets.
- Team page with email invitations, role changes and member removal.
- A banner across the dashboard when the desktop app is locked, with the reason.
- The desktop API and its reference document (docs/desktop-api.md).
- Branded 404 and error pages.
- A script that publishes the Windows installer to Vercel Blob and wires up the download button (scripts/upload-desktop-installer.mjs).

8. Suggested order of work

- 1 **Decide the desktop data model** (section 9): does the desktop app keep customers, sales and purchases locally, or sync them to this backend? This unblocks the largest remaining gap.
- 2 **Review the customers/suppliers/credit code** already sitting in the repository against that decision, and either adopt or discard it.
- 3 **Per-warehouse stock** before multiple warehouses are offered.
- 4 **Plan upgrade/downgrade proration**, so changing plans mid-cycle works cleanly.
- 5 **Switch Paystack to live keys** once business verification is approved.
- 6 **SMS or WhatsApp notifications**, once there's a need beyond email.

9. Open question

Does the desktop app store customers, sales and purchases in a local database, or should they sync to the web backend? If they sync, the customers/suppliers/purchases/sales/expenses work above is a large piece of backend work. If they stay local, most of it disappears.

10. Change log

Date	Change	Details
27 Sep 2026	Desktop download button wired up	The Windows button now downloads a real installer instead of linking nowhere: a script publishes it to the existing Vercel Blob store, and the button reads the URL and version from environment variables, showing “Coming soon” until they're set. macOS and Linux remain “Coming soon”. Verified in a real browser in both states, including that the linked file is actually fetchable.
27 Sep 2026	Payments with Paystack	Owners and Administrators pay by card, bank transfer or USSD through Paystack Checkout from the Billing page; a successful payment activates the subscription and, for cards, saves the card for automatic monthly renewal via a daily job. Renewals retry over a 3-day grace period, email on failure, and lock the account if they keep failing. Cancelling a paid subscription schedules the end instead of cutting access immediately, and can be undone. Every webhook is signature-verified and safe to receive twice. New admin Payments page with real collected revenue, failures and refunds; Insights now shows money actually collected. Verified with 75 checks against the real Paystack test-mode API, including signature and duplicate-webhook attacks, grace-period recovery, and a network failure during a renewal run. Currently in test mode.
26 Sep 2026	Support inbox and admin insights	Contact-form messages and messages sent from a customer's new Support page become tickets with a reference number, a confirmation email, and a spam trap, rate limit and length limits. Admins get a Support inbox (search, filters, threads, email replies, private notes, resolve and reopen), the overview lists tickets waiting for a reply, and a customer follow-up reopens a resolved ticket. A new Insights page shows MRR, ARR, new and churned MRR, trial-to-paid and churn rates, response time, a six-month table and revenue by plan. Verified with 38 new checks plus earlier suites.
26 Sep 2026	Two-factor authentication	Settings has a new Two-factor card: scan a QR code with an authenticator app, confirm a code, and save ten backup codes. Sign-in on the website and in the desktop app then asks for a code (the desktop API returns <code>two_factor_required</code> and accepts a code field). Codes work once, wrong codes are rate limited, backup codes can be regenerated, and turning it off needs the password and a code. Admins can see who has it on and reset it for someone locked out. Verified with 55 new checks including the official RFC 6238 test values, plus all earlier suites.
26 Sep 2026	Privacy Policy and Terms of Service updated	Both pages now describe what the product really does: sign-in and device records, the audit trail with IP address and device, who can see what (team roles and Aimify staff), sessions and signing out, the providers used (Vercel, Neon, Resend), retention of sessions and activity, team roles, plan limits and locked access after a trial. Claims that were ahead of the product (WhatsApp alerts, live payment providers, in-app export and deletion) are now worded as future or on request. Not legal advice: have a lawyer review before launch.

Date	Change	Details
26 Sep 2026	Revocable sessions and IP/device audit	Web and desktop sign-ins are now server-side sessions. Settings has a Signed-in devices list with Sign out and Sign out other devices; changing or resetting a password, an admin password reset, or removing a member signs out every device immediately; the desktop API gained POST /auth/logout and an optional deviceName at login. Audit entries record the IP address and device, visible to admins. Tokens issued before this change keep working until they expire or a password change. Verified with 41 new checks plus all earlier suites.
26 Sep 2026	Plans and enforced limits	New plans table with an admin Plans page (create, edit, activate, deactivate, set default) and a plan selector on each organization. Caps on team members, active warehouses and active products are enforced in the desktop API (403 with code plan_limit), when inviting and when accepting invitations. Customers see plan usage on Billing and seat use on Team; /me returns the plan, limits and usage; the admin revenue estimate now uses each organization's own plan price. Verified with 34 new checks plus the earlier API, team, admin and dashboard suites. The default plan keeps current behavior, so set real numbers on the Plans page.
26 Sep 2026	Trial and subscription emails	A daily job emails Owners and Administrators 3 days and 1 day before a trial ends and again when it ends, once per trial period, and it also marks lapsed trials as expired. Suspending, reactivating, extending, activating or cancelling a subscription now emails the same people. A failed send is retried on the next run. The job is protected by CRON_SECRET and refuses to run without it. Verified with 24 checks against the real database plus the existing 54 admin checks.
26 Sep 2026	Role limits in the desktop API	Every write endpoint now checks the caller's role after the subscription check: product create, edit and image, archive, categories and units, warehouse create and edit, and stock movements by type. Blocked calls return 403 with code forbidden_role, and /me now lists the signed-in role's permissions so the desktop app can hide controls. Documented in docs/desktop-api.md. Verified with 84 API checks covering all six roles against the real database.
26 Sep 2026	Team invites and roles	New Team page: Owners and Administrators invite people by email (link valid 7 days, resend and revoke), change roles and remove members. Invited people join with a verified email and skip onboarding; existing accounts without an organization can accept too. Administrators can't touch Owners or other Administrators. Only Owners can cancel the subscription, and only Owners and Administrators can edit the organization or logo. Whoever creates an organization is now its Owner. Removed members lose access to the dashboard and desktop app. Verified with 58 browser and database checks.

Date	Change	Details
26 Sep 2026	Overview pages fill the full width	Both overview pages were capped at a narrow column, leaving a blank strip on wide screens; they now use the full width. Admin gained Newest users and Most active organizations cards and a longer newest-organizations list; the customer overview gained a stock-health breakdown and a team card. Also fixed the admin overview failing when too many database queries ran at once.
26 Sep 2026	Richer customer overview	The dashboard overview now shows products, units in stock, stock value at cost and at retail price, low and out-of-stock lists, most valuable stock, a 14-day stock-flow chart, recent stock movements, products by category, subscription and trial countdown, a seven-step getting-started checklist and recent account activity, with friendly empty states. Verified with 30 checks including tenant isolation, in light and dark mode and at phone width.
26 Sep 2026	Richer admin overview	The overview grew from four cards to a full dashboard: growth this week and month, paying and trial counts with an estimated monthly revenue, users signed in today, unconfirmed emails, a Needs attention list (trials ending, expired trials, past due, suspended), a subscriptions-by-status chart, a 14-day sign-up chart, platform usage totals, newest organizations and latest activity. Verified with 20 checks against the real database, in light and dark mode and at phone width.
26 Sep 2026	Admin tables and activity history	Organizations and Users now show full details in expandable rows (company profile, owner and members, subscription, usage, last sign-in, recent activity) with more actions: extend trial by 7, 14 or 30 days, activate manually, send a confirmation link. Search and status filters were added. Activity gained Clear history (older than 7, 30 or 90 days, or everything): it shows how many entries will go, needs typing CLEAR for everything, and always leaves a permanent record of who cleared what. Verified with 54 browser checks against the real database.
26 Sep 2026	Email verification	Confirmation link emailed at sign-up; the link opens a page with a confirm button so email scanners can't use it up. Resend is rate-limited, unverified users are held before onboarding and the dashboard (also enforced inside the onboarding actions), and admins get an Unverified badge and a Verify email button. Existing accounts were grandfathered as confirmed.
26 Sep 2026	Company logo and product images (Vercel Blob), verified live	Logo upload on the Organization page and in the sidebar; product image endpoints for the desktop app. Images are checked by content, SVG is refused, old files are deleted on replace. Verified against the real Blob store: files are publicly readable, replaced and removed files are really deleted, the logo renders under the site's security headers, and no test files were left behind.
26 Sep 2026	Account layer and desktop API completion	Settings, organization profile, billing history and cancel now work; password reset by email; trial expiry and the extra subscription statuses; the desktop API refuses locked organizations; product edit and archive; configurable categories and units; warehouse create and edit; stock alerts. Also fixed a cross-tenant hole in stock movements.

Date	Change	Details
25 Sep 2026	First status report	Baseline audit of the proposed feature set against the repository.